

# **KDLS 24 UG – Prüfungsvorbereitung AP1**

## **Informationssicherheit & Datensicherheit (BSI)**

---

### **1. Informationssicherheit – Grundlagen**

Informationssicherheit umfasst den Schutz von Informationen und IT-Systemen vor Bedrohungen. Ziel ist es, Vertraulichkeit, Integrität und Verfügbarkeit von Informationen sicherzustellen.

### **2. Schutzziele der Informationssicherheit (BSI)**

#### **2.1 Vertraulichkeit**

- Nur berechtigte Personen dürfen Informationen lesen oder nutzen.
- Maßnahmen: Zugriffskontrollen, Rollenmodelle, Verschlüsselung.

#### **2.2 Integrität**

- Informationen müssen korrekt und unverändert bleiben.
- Maßnahmen: Prüfsummen/Hashes, Protokollierung von Änderungen, Versionskontrolle.

#### **2.3 Verfügbarkeit**

- Informationen und Systeme müssen zum benötigten Zeitpunkt nutzbar sein.
- Maßnahmen: Backups, Redundanz, Notfallkonzepte, Monitoring.

### **3. BSI-Ansatz: IT-Grundschutz**

- Standardisierte Vorgehensweise zur Einführung von Informationssicherheit.
- Bausteine, Gefährdungskataloge und Maßnahmenempfehlungen.
- Ziel: systematische, nachvollziehbare und überprüfbare Sicherheitskonzepte.

### **4. Typische Bedrohungen**

- Malware (Viren, Trojaner, Ransomware).
- Phishing und Social Engineering.

- Fehlkonfigurationen und menschliche Fehler.
- Hardwareausfälle, Stromausfälle, Brand, Wasser.

## **5. Datensicherheit – technische Maßnahmen**

### **5.1 Zugriffskontrolle**

- Passwortrichtlinien, Mehr-Faktor-Authentifizierung.
- Rollen- und Rechtekonzepte.

### **5.2 Verschlüsselung**

- Transportverschlüsselung (z. B. TLS für Web und E-Mail).
- Speicher-Verschlüsselung (z. B. Festplattenverschlüsselung, Datenbankverschlüsselung).

### **5.3 Backups und Wiederherstellung**

- Regelmäßige Sicherungen, Offsite-Backups.
- Test der Wiederherstellbarkeit (Restore-Tests).

### **5.4 Netzwerksicherheit**

- Firewalls, Segmentierung, VPN.
- Intrusion Detection/Prevention-Systeme.

### **5.5 Protokollierung & Monitoring**

- Logfiles für sicherheitsrelevante Ereignisse.
- Auswertung und Alarmierung bei Auffälligkeiten.

### **5.6 Patch- und Update-Management**

- Regelmäßige Sicherheitsupdates für Betriebssysteme und Anwendungen.
- Dokumentierte Prozesse für Tests und Rollout.

## **6. Physische Sicherheit**

- Zutrittskontrollen zu Serverräumen.
- Brandschutz, Klimatisierung, USV.
- Sichere Aufbewahrung von Datenträgern.

## **7. Abgrenzung: Datenschutz vs. Datensicherheit**

- **Datenschutz:** Schutz personenbezogener Daten und der Rechte der betroffenen Personen (DSGVO).
- **Datensicherheit:** technische und organisatorische Maßnahmen zum Schutz von Daten allgemein vor Verlust, Manipulation und Ausfall.

## KRITIS – Kritische Infrastrukturen

KRITIS-Unternehmen sind Organisationen, deren Ausfall erhebliche Auswirkungen auf die öffentliche Sicherheit, Versorgung oder das Gemeinwesen hätte. Für sie gelten besondere Anforderungen nach dem IT-Sicherheitsgesetz (BSI-Gesetz).

### KRITIS-Sektoren (gemäß BSI-Gesetz)

- **Energie** – Strom, Gas, Fernwärme
- **Wasser** – Trinkwasserversorgung, Abwasser
- **Ernährung** – Lebensmittelproduktion & -verteilung
- **Informationstechnik & Telekommunikation** – Netzinfrastruktur, Provider
- **Gesundheit** – Krankenhäuser, Labore, medizinische Versorgung
- **Finanz- & Versicherungswesen** – Banken, Börsen, Zahlungsverkehr
- **Transport & Verkehr** – Bahn, Luftfahrt, Schifffahrt, Logistik
- **Staat & Verwaltung** – Behörden, Parlamente, Verwaltungseinrichtungen
- **Medien & Kultur** – Rundfunk, Presse, kritische Kulturarchive

### Pflichten für KRITIS-Unternehmen

- Benennung eines **Informationssicherheitsbeauftragten (ISB)**
- Einführung eines Informationssicherheitsmanagementsystems (ISMS)
- Regelmäßige Sicherheitsüberprüfungen und Audits
- Meldung erheblicher IT-Sicherheitsvorfälle an das BSI
- Umsetzung umfangreicher technischer und organisatorischer Maßnahmen (TOMs)

KRITIS-Unternehmen unterliegen damit deutlich strengeren Anforderungen als normale Unternehmen.